

Política de Identidad y Acceso

Código: PIA-001

Versión: 1.0

Fecha de Vigencia: 01 de enero de 2026

Propietario: Dirección de Seguridad de la Información

1. Objetivo

Establecer los lineamientos para la gestión de identidades digitales, autenticación, autorización y control de acceso a los recursos tecnológicos de la organización, garantizando que únicamente las personas autorizadas puedan acceder a la información y sistemas corporativos.

2. Alcance

Esta política aplica a:

- Empleados, contratistas y proveedores.
- Usuarios internos y externos con acceso autorizado.
- Sistemas, aplicaciones, redes y servicios en la nube.
- Cuentas privilegiadas, administrativas y de servicio.
- Dispositivos y plataformas tecnológicas administradas por la organización.

3. Principios Generales

1. Todo usuario deberá contar con una identidad digital única.
2. Los accesos serán otorgados bajo el principio de mínimo privilegio.
3. Los permisos deberán asignarse según las funciones y responsabilidades del usuario.
4. El acceso a información sensible requerirá controles de autenticación reforzados.
5. Todas las actividades de acceso deberán ser registradas y auditables.

4. Gestión de Identidades

- Toda cuenta deberá estar asociada a una persona o proceso identificado.
- Las cuentas genéricas estarán prohibidas salvo autorización excepcional documentada.
- La creación, modificación y eliminación de cuentas deberá seguir un proceso formal de aprobación.
- Las identidades deberán mantenerse actualizadas durante todo el ciclo de vida del usuario.

5. Gestión de Accesos

Los accesos deberán:

- Ser aprobados por el responsable del área correspondiente.
- Basarse en el rol y funciones del usuario.
- Revisarse periódicamente para asegurar su vigencia.
- Revocarse inmediatamente cuando dejen de ser necesarios.
- Documentarse en los sistemas de gestión definidos por la organización.

6. Autenticación

La organización implementará los siguientes controles:

- Contraseñas robustas y únicas para cada usuario.
- Autenticación multifactor para sistemas críticos.
- Bloqueo automático de cuentas ante intentos fallidos repetitivos.
- Mecanismos seguros para restablecimiento de contraseñas.
- Protección de credenciales frente a divulgación o uso indebido.

7. Gestión de Cuentas Privilegiadas

Las cuentas administrativas deberán:

- Utilizarse exclusivamente para tareas de administración.
- Contar con monitoreo y registro de actividades.
- Ser revisadas regularmente por Seguridad de la Información.
- Utilizar autenticación multifactor obligatoria.
- Mantener una justificación documentada de su asignación.

8. Revisión Periódica de Accesos

Los responsables de cada área deberán verificar, al menos semestralmente:

- La vigencia de los usuarios activos.
- Los permisos asignados.
- Los accesos privilegiados existentes.
- Las excepciones autorizadas.

Cualquier acceso injustificado deberá ser removido de manera inmediata.

9. Baja de Usuarios

Cuando un colaborador finalice su relación con la organización:

- Sus accesos deberán deshabilitarse de forma oportuna.
- Los permisos asignados deberán revocarse.

- Los activos tecnológicos deberán recuperarse según corresponda.
- Se deberá conservar evidencia del proceso de baja.

10. Monitoreo y Auditoría

La organización podrá monitorear y auditar el uso de identidades y accesos para:

- Detectar actividades no autorizadas.
- Investigar incidentes de seguridad.
- Verificar el cumplimiento normativo.
- Evaluar la efectividad de los controles implementados.

11. Incumplimiento

El incumplimiento de esta política podrá resultar en la suspensión o revocación de accesos, medidas disciplinarias y otras acciones definidas por la organización de acuerdo con la gravedad de la situación.

12. Revisión de la Política

La presente política será revisada anualmente o cuando existan cambios significativos en los procesos de gestión de identidades, requisitos regulatorios o tecnologías de autenticación.

Aprobado por: Comité de Seguridad de la Información **Próxima revisión:** 01 de enero de 2027